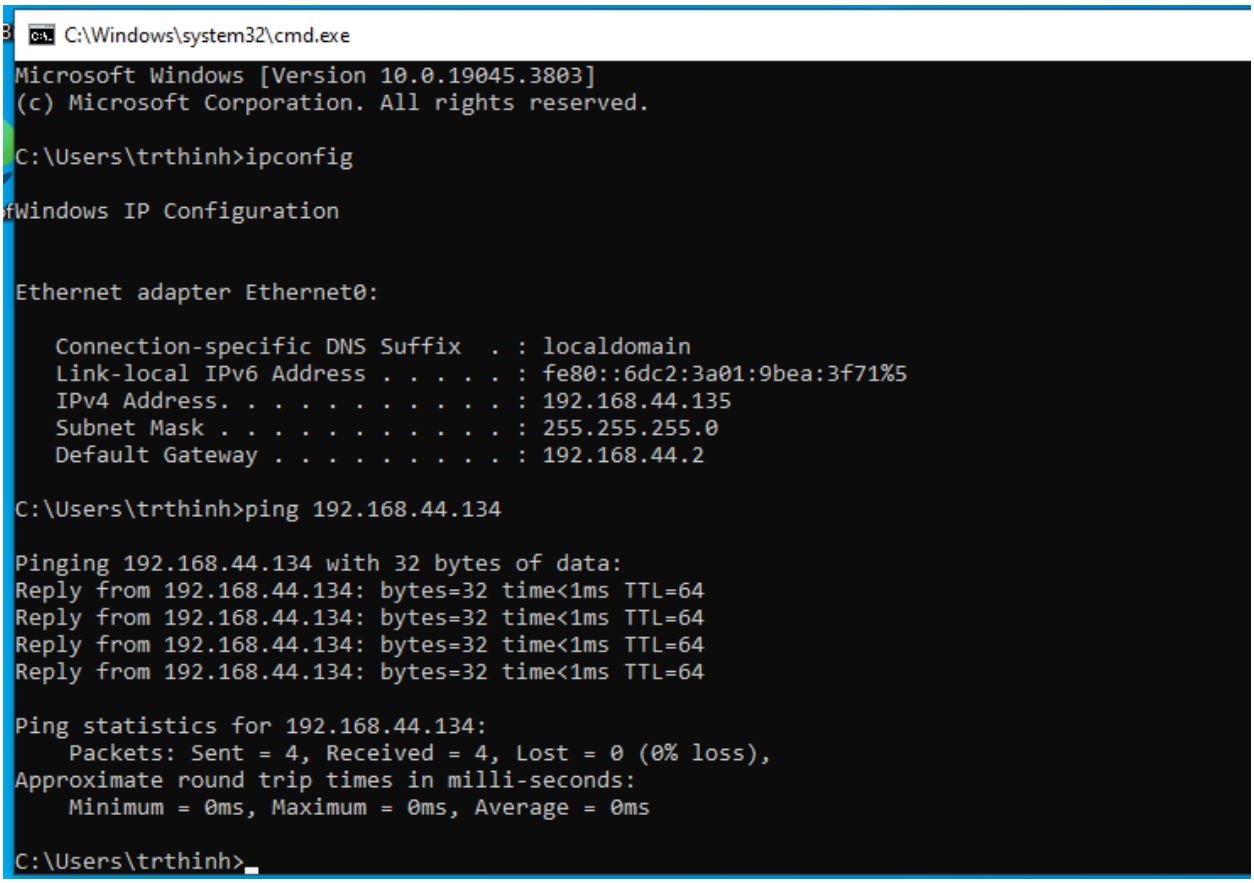
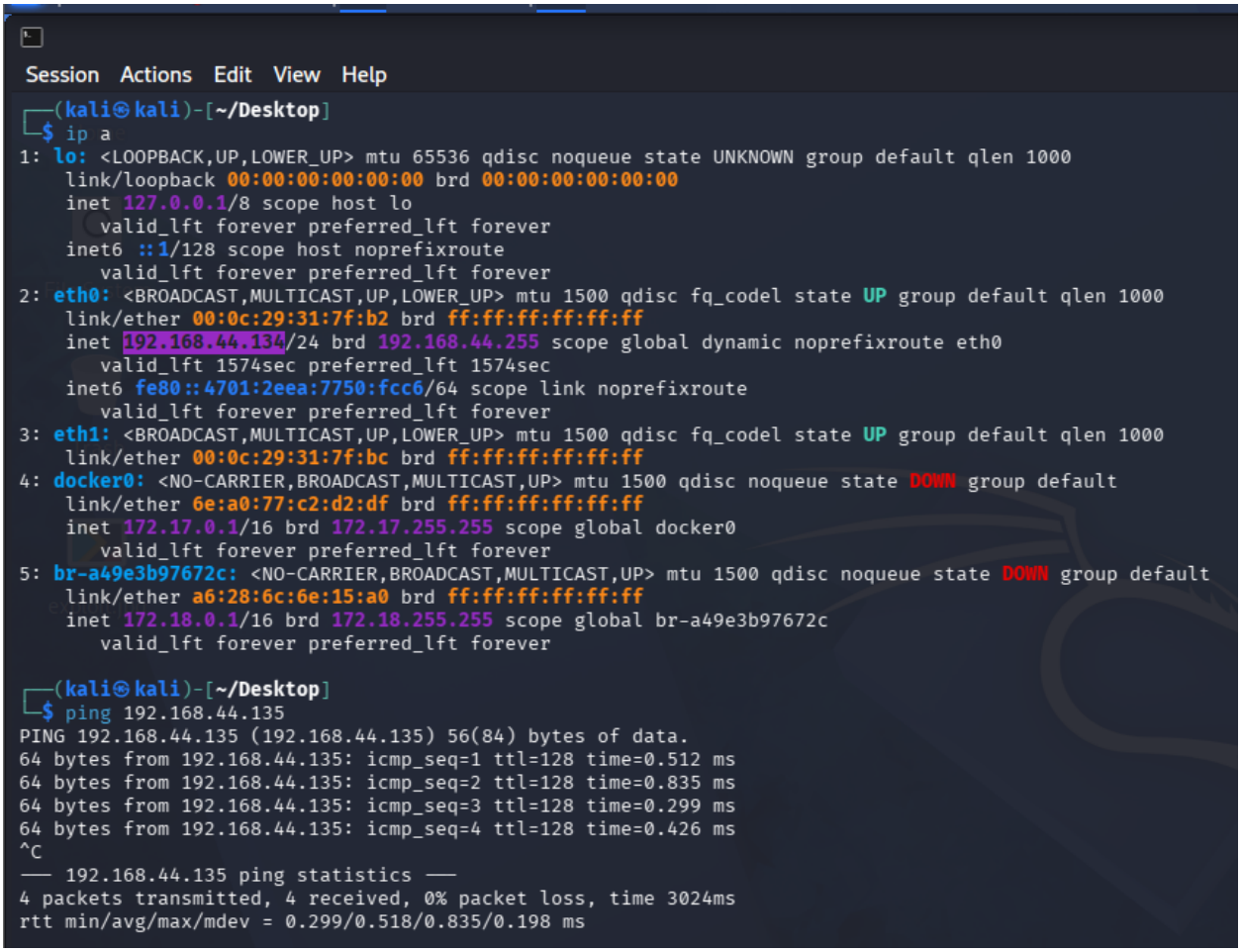
Trần Tăng Trường Thịnh 2387701939

BÀI 4: XÁC MINH, KHAI THÁC LỖ HỔNG PHP VÀ XSS

4.1 KHAI THÁC LỖ HỔNG PHP



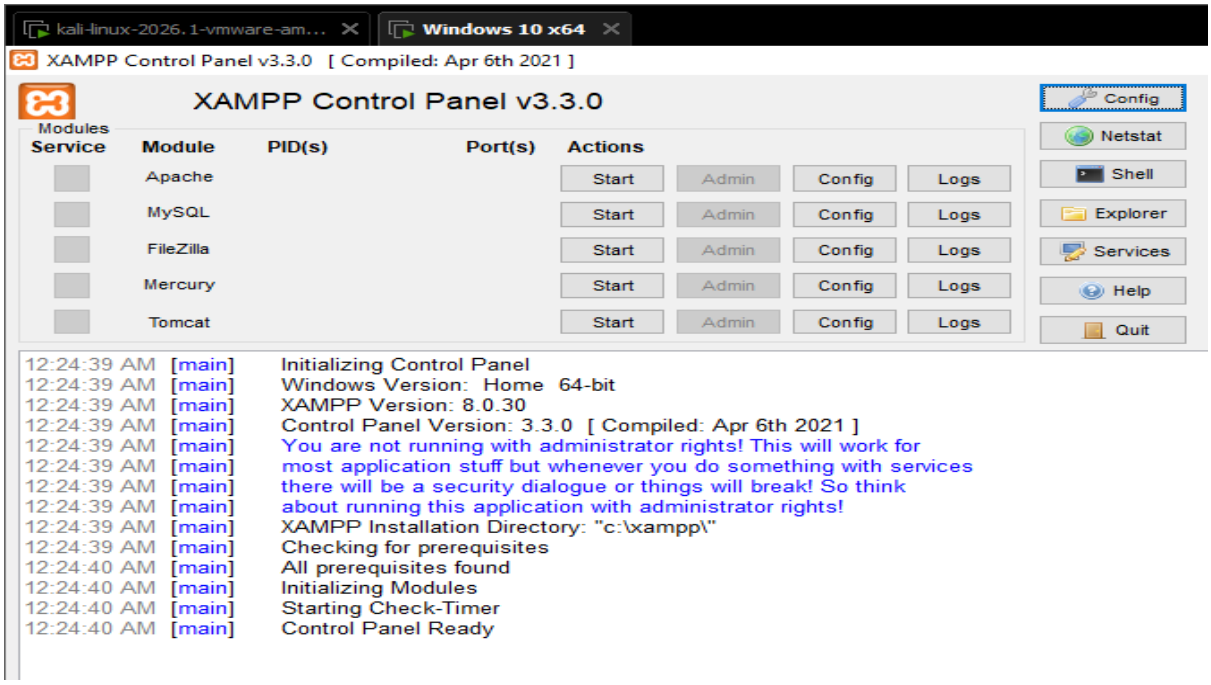
Hình 1: Kiểm tra kết nối giữa windows và máy kali. IP máy windows là *192.168.44.135*



Hình 2: IP của máy kali là *192.168.44.134*

a. Khai thác lỗ hổng chứng chỉ mặc định trong XAMPP

Quét mục tiêu bằng công cụ Nmap



Hình 3: Khởi động XAMPP



Hình 4: Truy cập Dashboard XAMPP thành công

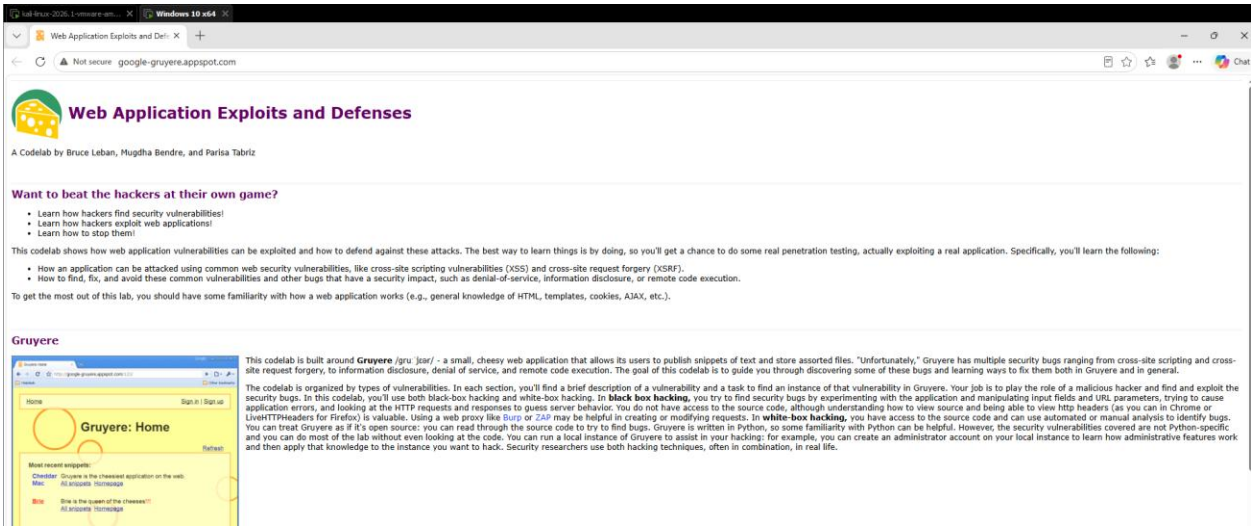


Hình 5: Kết quả quét Nmap máy Windows mục tiêu

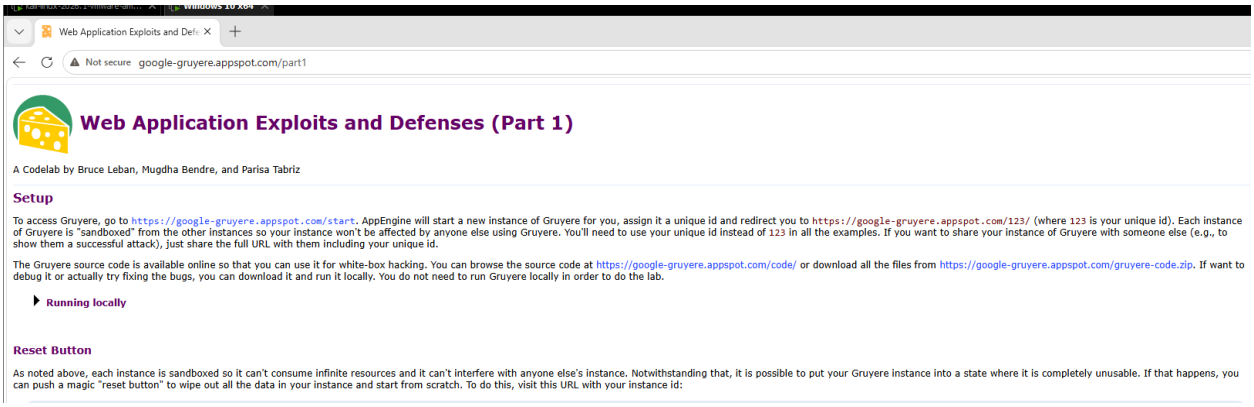
Sử dụng lệnh nmap -A 192.168.44.135 từ máy Kali Linux để quét máy Windows mục tiêu. Kết quả cho thấy máy mục tiêu đang hoạt động và mở hai dịch vụ web:

- Cổng *80/tcp* mở, chạy dịch vụ HTTP Apache *2.4.58* kèm PHP *8.0.30.*
- Cổng *443/tcp* mở, chạy dịch vụ HTTPS Apache *2.4.58.*
- Nmap nhận diện tiêu đề trang là *Welcome to XAMPP*, xác nhận XAMPP đã được cài đặt và Apache đang hoạt động.
- Hệ điều hành mục tiêu được Nmap phỏng đoán là Windows 10/11; đây chỉ là dự đoán vì nhiều cổng khác đang ở trạng thái *filtered.*

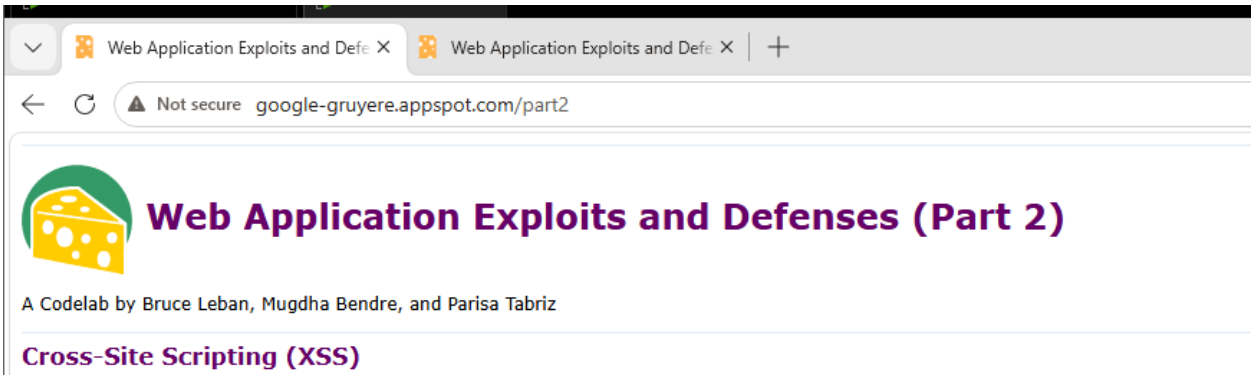
4.2 KHAI THÁC LỖ HỔNG XSS VỚI GOOGLE GRUYERE



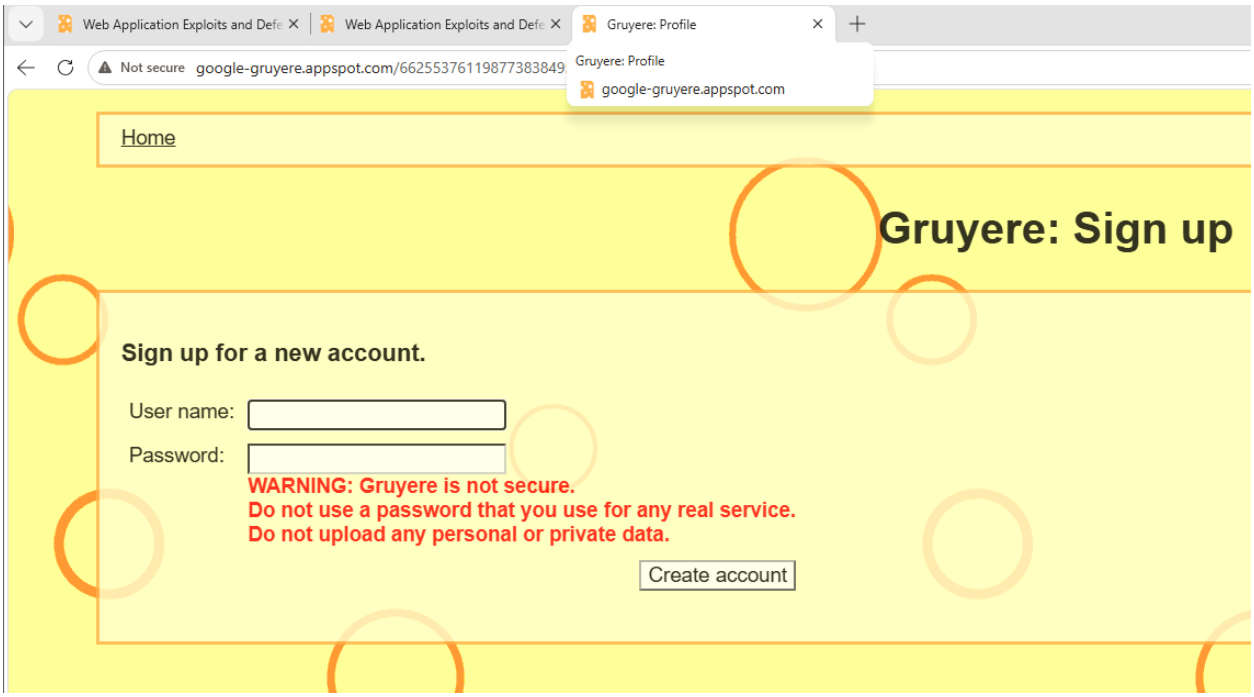
Hình 6: Truy cập trang web



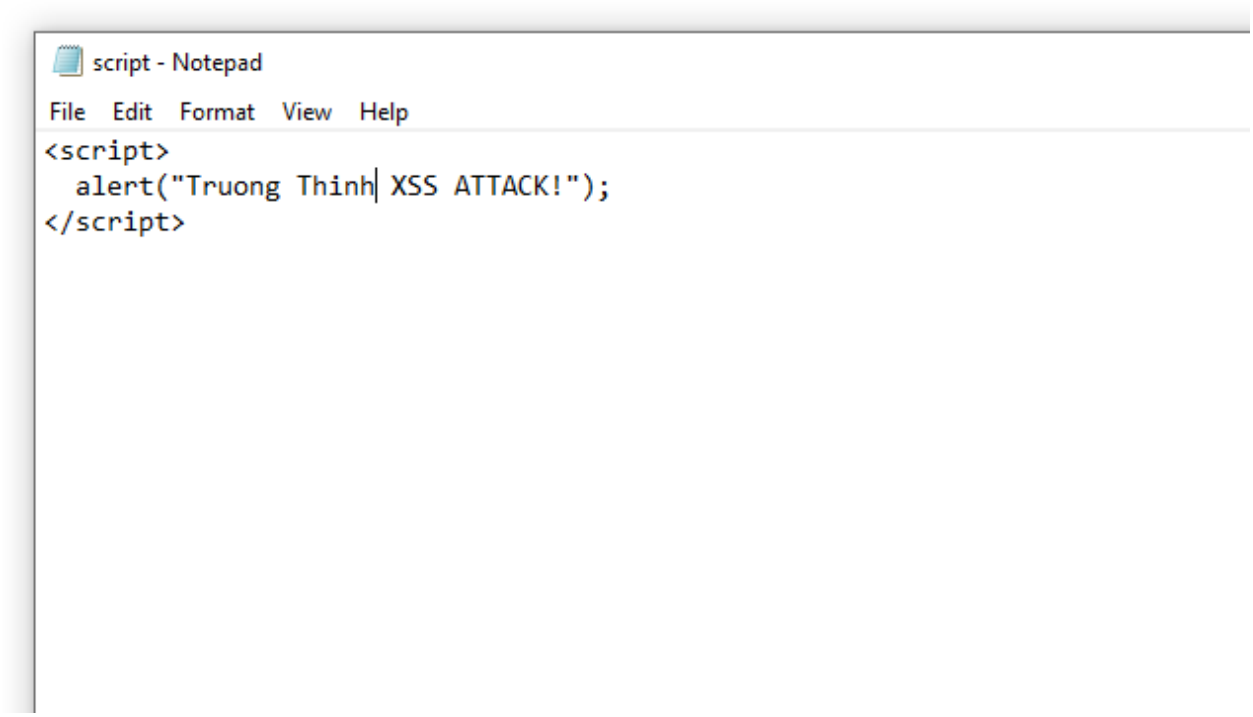
Hình 7: Web Application Exploits and Defenses (Part 1).



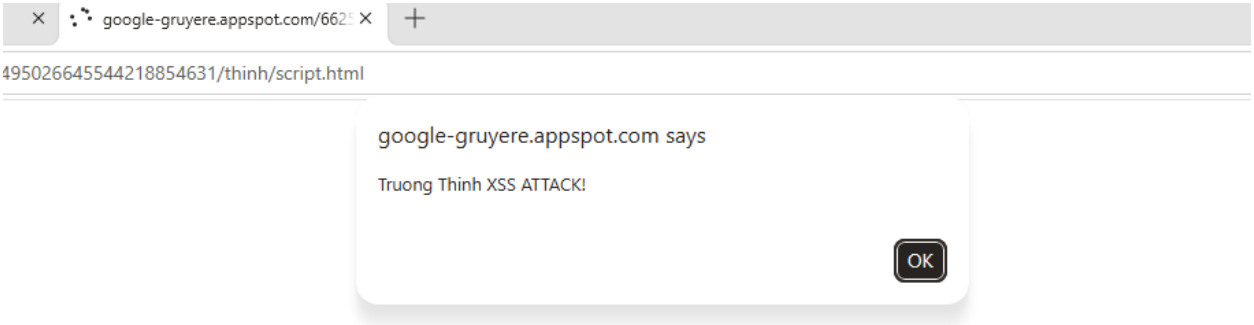
Hình 8: Web Application Exploits and Defenses (Part 2)



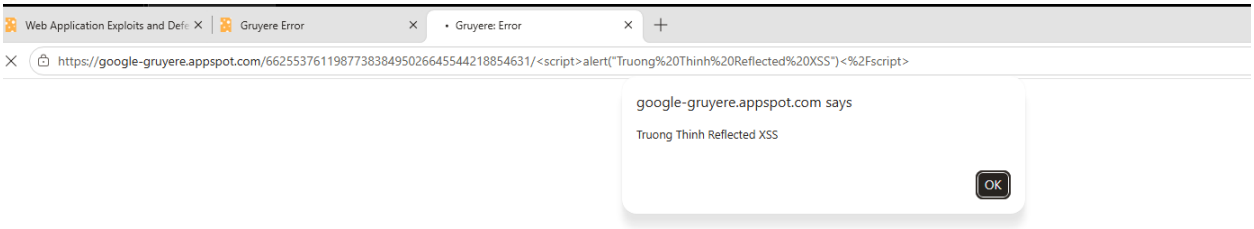
Hình 9: Khởi tạo instance Gruyere



Hình 10: File script.html



Hình 11: Hộp thoại cảnh báo "Truong Thinh XSS ATTACK!" kích hoạt thành công từ tệp script.html đã tải lên.



Hình 12: Khai thác Reflected XSS thành công. Payload được chèn trong đường dẫn URL và không được ứng dụng mã hóa HTML trước khi hiển thị trong trang lỗi. Vì vậy, trình duyệt đã thực thi JavaScript và hiển thị hộp thoại “Truong Thinh Reflected XSS”.